

LIVRABLE 3 : PLAN D'IMPLÉMENTATION DU PROGRAMME ET PLAN PILOTE (MARKETING)

Certification Architecte en IA (RNCP 38777 - bloc 1) • Feuille de route opérationnelle, RACI et gestion de crise

Auteur : Caroline HEYMES

Date : 9 juin 2026

Cas d'étude : Spotify S.A.

TABLE DES MATIÈRES

1. Introduction et vision stratégique	Page 1
2. Feuille de route d'implémentation globale (18 mois)	Page 2
3. Matrice RACI étendue et organisation des instances	Page 3
4. Registre des risques du programme (risk register)	Page 4
5. Plans de contingence techniques de haute gravité (Protocoles Alpha et Beta)	Page 5
6. Plan pilote opérationnel : division marketing (mois 1 à 6)	Page 6
7. Conclusion et recommandations	Page 7

1. INTRODUCTION ET VISION STRATÉGIQUE

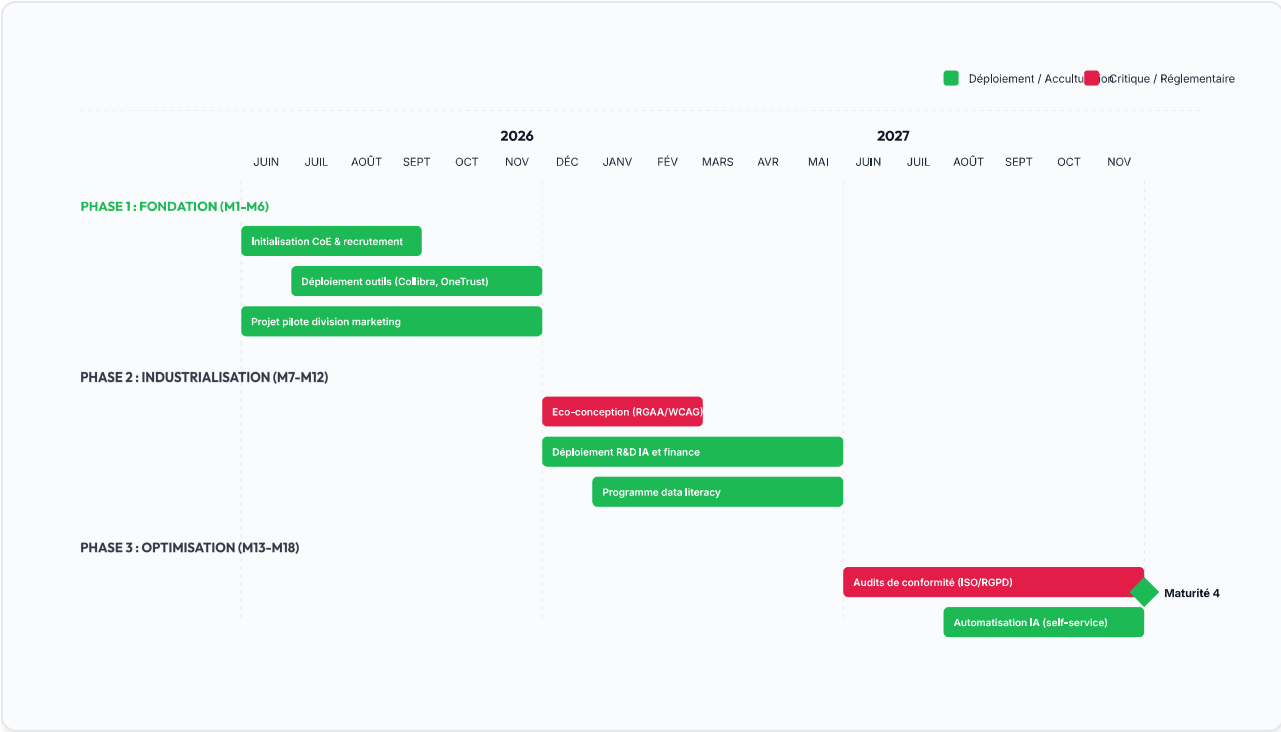
Déployer un programme de gouvernance des données au sein d'une organisation tournée vers le streaming en temps réel et l'IA comme Spotify requiert d'éviter les pièges d'une bureaucratie trop rigide. Le cadre mis en place doit accompagner l'innovation technique tout en garantissant un niveau élevé de sécurité et de conformité.

Ce document présente le **plan d'implémentation de la gouvernance sur 18 mois**, conçu d'après la charte de données (Livrable 2), et détaille son application à travers un **projet pilote au sein de la division marketing (mois 1 à 6)**. Ce plan intègre :

- Les standards de l'industrie, notamment le référentiel **DAMA-DMBOK2** pour la sémantique et la norme **ISO/IEC 27001:2022** pour la sécurité de l'information.
- Les exigences de conformité en matière d'**accessibilité numérique (RGAA 4.1.2 et WCAG 2.2)** pour les outils d'aide à la décision.
- Des **protocoles de gestion de crise opérationnels** devant faire face aux sinistres techniques et de données d'une gravité exceptionnelle.

2. FEUILLE DE ROUTE D'IMPLÉMENTATION GLOBALE (18 MOIS)

La feuille de route s'étend sur 18 mois et s'organise en trois phases distinctes, permettant d'assurer l'adoption progressive et durable des nouvelles pratiques au sein de Spotify.



Phase 1 : Fondation (M1-M6)

Objectif : Structurer les bases humaines et techniques, puis démontrer la valeur du programme via le pilote.

- Recrutement opérationnel et constitution du CoE (CDO, DPO, architectes de données).
- Acquisition et déploiement initial des solutions (Collibra, Talend, OneTrust).
- Lancement du projet pilote de la division marketing.
- Cartographie sémantique initiale et lignage des données de la zone pilote.

Phase 2 : Industrialisation (M7-M12)

Objectif : Déployer le cadre sur d'autres divisions clés et intégrer les standards d'accessibilité numérique.

- Extension du cadre aux divisions **R&D IA et finance** (certifiée PCI-DSS).
- Mise en conformité **RGAA 4.1.2 et WCAG 2.2** des tableaux de bord (Tableau, Looker) et catalogues.
- Déploiement du programme d'acculturation sémantique (Data Literacy Program) pour les métiers.

Phase 3 : Optimisation (M13-M18)

Objectif : Automatiser les contrôles et viser l'excellence opérationnelle certifiée.

- Audits bi-annuels de conformité et de sécurité (ISO/IEC 27001:2022 et RGPD).
- Suivi automatisé du lignage (*data lineage*) via l'analyse des requêtes de production.
- Évaluation finale ciblant le **niveau 4 de maturité de Gartner** (gouvernance intégrée).

3. MATRICE RACI ÉTENDUE ET ORGANISATION DES INSTANCES

Pour délimiter précisément les rôles et éviter les ambiguïtés opérationnelles, Spotify utilise une matrice RACI étendue appliquée à neuf chantiers majeurs de la gouvernance.

Description des instances et des rôles

CDO : Chief Data Officer (pilote stratégique data).
DPO : Data Protection Officer (garant de la vie privée/RGPD).
Comité (DGC) : Data Governance Committee (arbitre central).

Data Owner (DO) : Propriétaire métier (directeurs de domaines).
Data Steward (DS) : Gestionnaire opérationnel sémantique.
Data Custodian (DC) : Gardien de l'infrastructure physique.
Data Engineer (DE) : Développeur des pipelines de données.

CHANTIERS DE GOUVERNANCE	CDO	DPO	COMITÉ	DO	DS	DC	DE
1. Définition des politiques et de la charte	A	C	R	C	C	I	I
2. Validation du modèle de maturité	A	I	R	C	R	I	I
3. Catalogage et métadonnées (Collibra)	I	I	I	A	R	C	R
4. Contrôle qualité et nettoyage de données	I	I	I	A	R	C	R
5. Analyses d'impact (AIPD / PIA)	I	A	C	R	R	I	I
6. Gestion des habilitations et accès	I	C	I	A	R	R	I
7. Intégration de l'accessibilité (RGAA)	I	I	I	A	C	C	R
8. Exécution des purges et anonymisation	I	A	I	C	C	R	R
9. Activation du protocole de crise	R	A	R	I	I	R	R

Légende du RACI :

R **Responsible** : réalise opérationnellement la tâche.

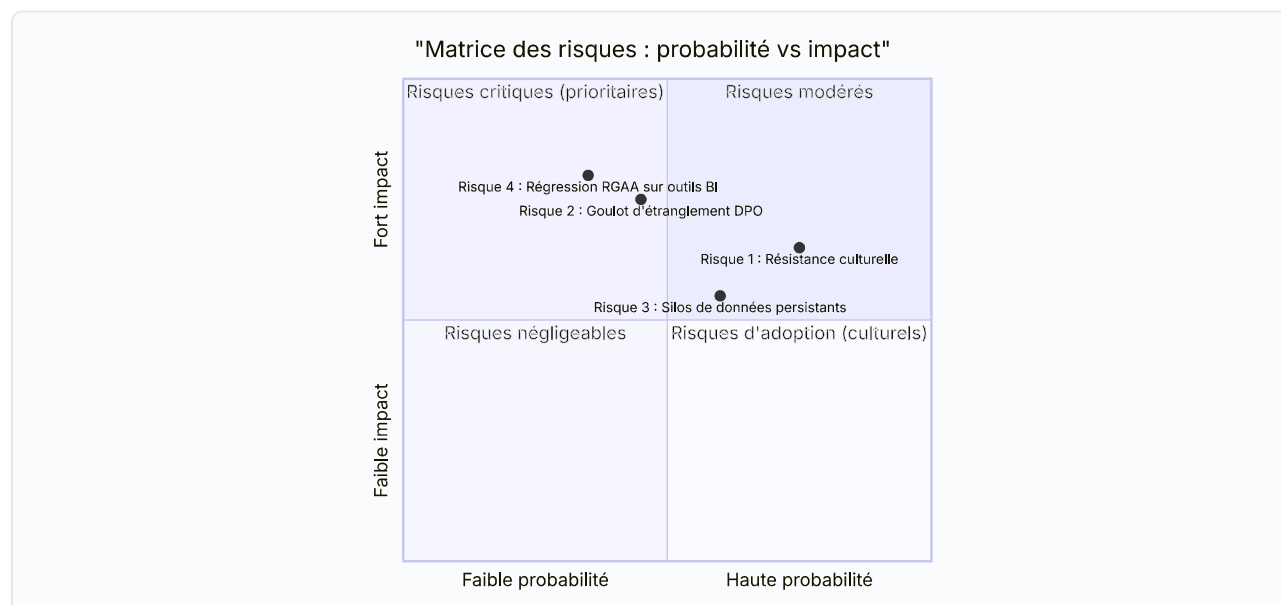
A **Accountable** : approuve et endosse la responsabilité finale.

C **Consulted** : apporte son avis ou expertise en amont.

I **Informed** : tenu informé du statut de la tâche.

4. REGISTRE DES RISQUES DU PROGRAMME

Le déploiement de ce programme présente des risques d'adoption culturelle, d'organisation réglementaire et d'intégration technique qu'il convient de mitiger par des actions claires.



1. Résistance culturelle des Squads R&D

PROB : 4/5 | IMP : 3/5

"La gouvernance ralentit le déploiement de l'IA"

Conséquence : Contournement des règles de catalogage, stockage de données d'entraînement d'IA hors des environnements contrôlés.

Mitigation : Établir un réseau d'ambassadeurs (*Data Champions*) ; prouver que le catalogue accélère l'accès de 40% ; intégrer la gouvernance dans les OKR d'équipes.

2. Goulot d'étranglement réglementaire

PROB : 3/5 | IMP : 4/5

"Surchauffe du DPO sur les analyses d'impact (AIPD)"

Conséquence : Ralentissement du déploiement des nouvelles fonctionnalités de recommandation IA basées sur l'analyse comportementale.

Mitigation : Industrialiser les formulaires d'AIPD automatisés dans OneTrust ; déléguer la collecte sémantique initiale aux Data Stewards métiers.

3. Silos technologiques persistants

PROB : 4/5 | IMP : 3/5

"Incompatibilité des outils métiers existants"

Conséquence : Impossibilité d'assurer une traçabilité complète de bout en bout (*lineage*), persistance d'erreurs de qualité en production.

Mitigation : Imposer l'utilisation d'API sémantiques standardisées pour tout achat/création d'outils ; revue d'architecture data obligatoire lors du cadrage.

4. Régression accessibilité BI (Non-Conformité)

PROB : 3/5 | IMP : 4/5

"Tableaux de bord analytiques non conformes RGAA"

Conséquence : Exclusion des collaborateurs en situation de handicap, non-conformité face aux standards juridiques d'inclusion.

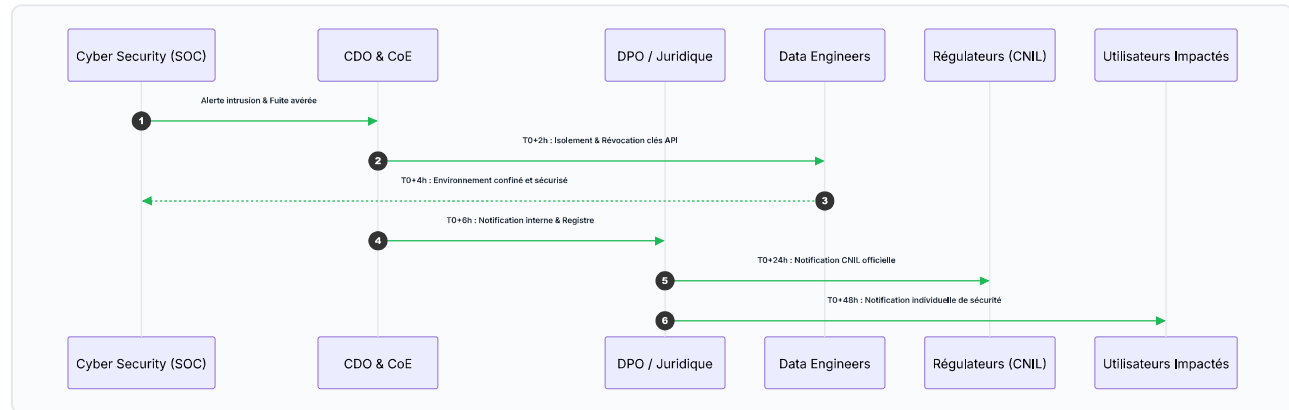
Mitigation : Diffuser un pack de modèles décisionnels pré-audités (contrastes adaptés, ARIA) ; test d'accessibilité obligatoire lors de la livraison.

5. PLANS DE CONTINGENCE TECHNIQUES DE HAUTE GRAVITÉ

[IMPORTANT] Face aux cyber-menaces et incidents matériels d'une gravité exceptionnelle, Spotify met en œuvre des protocoles techniques stricts de reprise d'activité (DRP) et de confinement immédiat.

Protocole Alpha : incident de violation de données personnelles de masse

Scénario d'incident : Exfiltration cyber massive des e-mails, mots de passe hachés, identifiants et données de localisation de 10 millions d'abonnés Spotify (origine : clé Kubernetes fuitée ou faille applicative).



Procédure d'urgence pas-à-pas (Chronologie)

- 1 Phase d'alerte (T0 à T+2h)**
Détection par le SOC d'un volume de trafic sortant anormal. Transmission immédiate au CDO et au DPO. Constitution instantanée de la cellule de crise cyber (CDO, DSI, DPO).
- 2 Confinement technique (T+2h à T+12h)**
Les Data Engineers isolent le sous-réseau réseau affecté pour stopper la fuite. Révocation globale des clés API et rotation immédiate des certificats de production. Application d'un *hotfix* de sécurité.
- 3 Évaluation de la violation (T+12h à T+24h)**
Le DPO et l'équipe SecOps mesurent la portée de l'attaque (champs volés, nombre précis de comptes concernés, risques d'usurpation). Inscription de l'événement dans le registre interne des violations.
- 4 Notification légale de contrôle (T+24h à T+72h)**
Le DPO soumet la déclaration officielle d'incident à la CNIL sous 72 heures au titre de l'article 33 du RGPD, détaillant l'origine, les impacts potentiels et les corrections prises.
- 5 Notification et alerte des abonnés (T+24h à T+72h)**
Envoi d'une notification individuelle transparente par email aux abonnés touchés : conseils de sécurité pour modifier le mot de passe, alertes anti-phishing, et ouverture d'une cellule support dédiée.

Protocole Beta : reprise après sinistre de données et restauration KMS (DRP)

Scénario : Corruption accidentelle de la clé maîtresse (Master Encryption Key) Cloud KMS. Les tables de profils d'écoute deviennent illisibles, provoquant l'interruption mondiale de la recommandation de l'application client.

1 Déclaration de sinistre & Isolement (T0 à T+30min)

Le CDO déclare le sinistre technique de niveau 1. Les écritures du Data Lake sont suspendues. Les flux Kafka entrants sont automatiquement déviés vers un stockage tampon temporaire.

2 Restauration HSM et clé Cloud KMS (T+30min à T+2h)

Activation du module matériel Cloud HSM de secours. Application du ****partage de secrets de Shamir**** : convocation et accord physique de 3 administrateurs de clés sur 5 pour recréer la clé racine à partir d'une sauvegarde physique hors-ligne (***Air-Gapped Vault***).

3 Contrôle de déchiffrement & Intégrité (T+2h à T+4h)

Lancement de scripts de validation automatique de déchiffrement sur un panel d'abonnés tests. Validation de la signature cryptographique d'intégrité (hachage) des données restaurées.

4 Rétablissement et dépilage nominal (T+4h à T+8h)

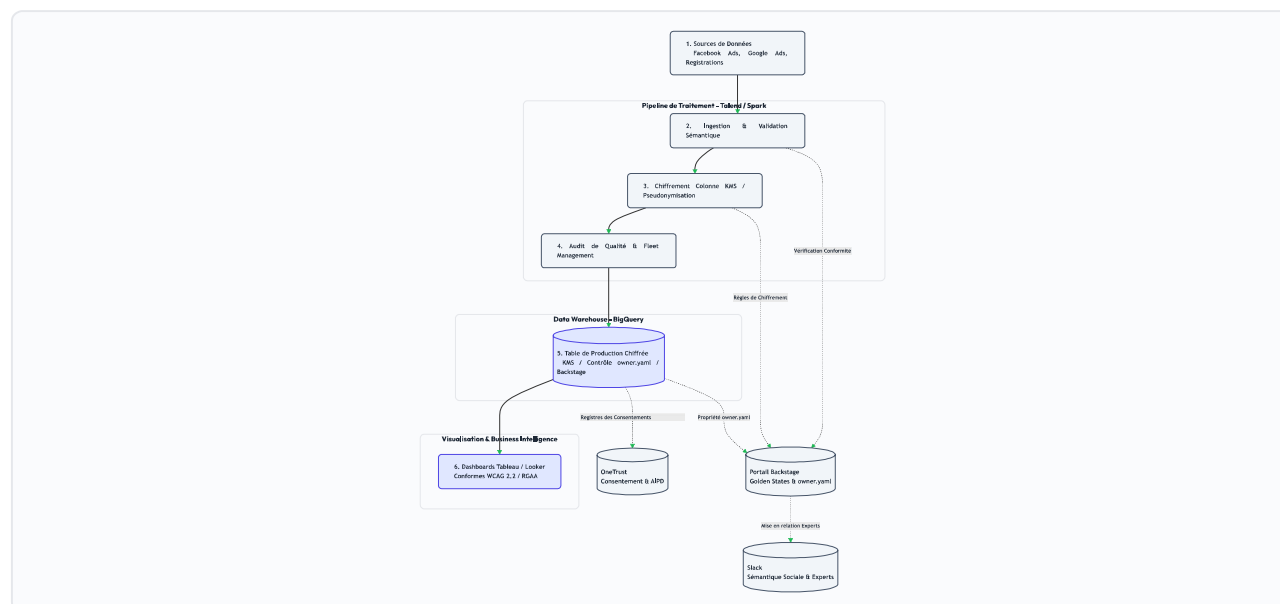
Restauration des bases de profils (cible de perte de données - ****RPO : 2h maximum****). Dépilage progressif des flux de données Kafka en tampon pour éviter la surcharge. Retour nominal de l'application cliente dans le monde entier (cible de récupération - ****RTO : 8h maximum****).

6. PLAN PILOTE OPÉRATIONNEL : DIVISION MARKETING (MOIS 1 À 6)

Pour éprouver l'efficacité du cadre de gouvernance de Spotify avant son extension globale, la division marketing est choisie comme environnement pilote pour traiter les données prospects, de campagnes et de profils. Ce pilote s'inscrit dans la vision d'un écosystème décentralisé (***Data Mesh*** en libre-service) capable de supporter un traitement massif atteignant des centaines de milliards d'événements par jour, tout en garantissant une visibilité centrale sur la santé technique et la traçabilité de chaque actif.

6.1. Architecture technique du pipeline de données sécurisé

Le logigramme ci-dessous schématise le parcours d'intégration des données d'acquisition publicitaire. Les contrôles sont intégrés nativement au flux des ingénieurs via le portail développeur centralisé ****Backstage**** et comparés en temps réel à des modèles de conformité (****Golden States****) :



Dans cette architecture, la gouvernance de flotte (***fleet management***) orchestre la conformité en continu : chaque pipeline de la division marketing est scanné en temps réel. S'il s'écarte du standard de référence (****Golden State****), les développeurs visualisent les écarts sur leur portail Backstage et disposent de trajectoires de correction guidées et automatiques. De plus, le catalogue de données associe chaque actif à un canal ****Slack**** spécifique, convertissant la découverte technique en une expérience collaborative basée sur la cartographie de l'expertise humaine en temps réel.

6.2. Configurations outillées précises du pilote marketing

A. Backstage (Portail développeur & conformité)

- **Fichiers `owner.yaml`** : Déclare l'équipe responsable (ex. `squad-marketing-analytics`) et le domaine fonctionnel directement dans le dépôt Git.
- **Plugin "Data Health"** : Compare le code du pipeline aux standards du **Golden State** et propose des correctifs automatisés de conformité.
- **Plugin "Data Lineage"** : Génère automatiquement la carte des dépendances techniques, de la collecte brute jusqu'aux tables de BigQuery.

B. Talend & Cloud KMS (Qualité et chiffrement)

- **Validation sémantique** : Module **DataQuality** pour valider à l'ingestion les formats de données (e-mails, numéros, codes pays ISO-3166-1).
- **Chiffrement KMS à la colonne** : Cryptage asymétrique fort (AES-256) au repos des e-mails/téléphones au vol. Seuls les comptes IAM autorisés déchiffrent.

C. OneTrust & cycle de vie (Consentement & purge)

- **Registre de consentement** : Statut opt-in/opt-out publicitaire propagé en direct comme règle d'accès au niveau des bases.
- **Purges par le code** : Les appels de droit à l'oubli OneTrust transmettent des signaux API, purgeant BigQuery sous 48h. Suppression automatique des logs bruts inactifs après 24 mois.

D. Slack & sémantique sociale (Cartographie humaine)

- **Lien direct Backstage** : Liaison dynamique d'un actif sémantique à un canal de discussion technique en direct (ex. `#data-help-marketing`).
- **Détection d'experts** : Identification automatisée via Git des trois principaux contributeurs techniques récents, affichés comme experts.

6.3. Indicateurs clés de performance (KPI) et métriques du pilote

CATÉGORIE	INDICATEUR DE PERFORMANCE (KPI)	OBJECTIF CIBLE	FRÉQUENCE
Qualité des données	Taux d'exhaustivité et de conformité des profils prospects	> 98,5 %	Hebdomadaire
Qualité des données	Taux de doublons identifiés dans la base marketing	< 0,5 %	Mensuelle
Catalogage	Taux d'actifs de données marketing documentés dans Collibra	100 %	Mensuelle
Conformité & droits	Délai moyen de compilation et d'accès aux données (format JSON)	< 48 heures	Temps réel
Conformité & droits	Délai d'exécution d'une demande d'effacement (droit à l'oubli)	< 72 heures	Temps réel
Accessibilité	Proportion de rapports BI marketing conformes au RGAA 4.1.2	100 %	Trimestrielle

7. CONCLUSION ET RECOMMANDATIONS

Ce plan d'implémentation opérationnel pose les bases méthodologiques attendues d'un cadre de gouvernance robuste. Il garantit la qualité de nos données tout en accompagnant l'élan d'innovation technologique de Spotify.

Recommandations clés pour la soutenance orale :

1. Valoriser le ROI : Expliquez au jury qu'une base de données prospects exempte de doublons ou d'erreurs réduit de 15% le gaspillage publicitaire (Infonomics).

2. Appuyer sur la résilience : L'existence de **plans de secours cyber formalisés** (Critère 2.5) protège Spotify des sanctions du RGPD (jusqu'à 4% du CA mondial).

3. Promouvoir l'accessibilité : La mise en conformité des rapports BI au **RGAA/WCAG** favorise l'inclusion et enrichit le vivier de talents de la R&D.